Cloud Adoption Security Assessment

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Cloud Adoption Security Assessment 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

Outcome . . . 6

Scope boundary . . . 6

1. Solution Overview — Cloud Adoption Security Assessment 6

What this assessment is . . . 6

The six pillars this assessment scores . . . 7

How the assessment works . . . 7

What you can control . . . 8

Scope — what's in . . . 8

Scope — what's out (be honest with buyers) . . . 8

Authentication and connections used . . . 8

The standard deployment model . . . 9

2. Requirements — Cloud Adoption Security Assessment 9

R1. Security Reader (or Global Reader) across Microsoft 365 / Entra . . . 9

R2. Azure **Reader** at every in-scope subscription (and Security Reader on Defender for Cloud) . 9

R3. Microsoft Graph read scopes consented . . . 10

R4. PowerShell 7+ with the Microsoft.Graph, Az, and (optional) Defender modules . . . 10

R5. A defined, documented assessment scope . . . 10

R6. Microsoft Secure Score enabled and populated . . . 10

R7. (Optional) Sentinel / Advanced Hunting read access for corroborating KQL . . . 11

R8. A secure destination for the findings report . . . 11

Global Requirements — Assessments (category-level) 11

G1. The workload/tenant being assessed . . . 11

G2. Read-only assessor access (least privilege) . . . 11

G3. Microsoft Graph / Az / management API access . . . 12

G4. Licensing for the products in scope . . . 12

G5. Scope definition and a point-in-time baseline . . . 12

G6. Best-practice reference baseline . . . 12

G7. Output handling and confidentiality . . . 12

G8. Remediation ownership (for the paired remediation) . . . 12

3. Implementation — Cloud Adoption Security Assessment 13

Stage 0 — Assess: prepare and validate access (read-only) . . . 13

Stage 1 — Configure: choose the baseline and pilot scope . . . 14
Stage 2 — Pilot: discover and score the pilot scope (read-only) . . . 14
Stage 3 — Validate: confirm the pilot findings are real . . . 15
Stage 4 — Expand: run the whole estate and produce the roadmap . . . 16
Re-run to trend . . . 16
5. Testing — Cloud Adoption Security Assessment 17
Gate 1 — Access is valid and read-only . . . 17
Gate 2 — Discovery is complete (no empty pillars) . . . 17
Gate 3 — Secure Score reconciles with the portal . . . 17
Gate 4 — Conditional Access gaps are real . . . 17
Gate 5 — (Optional) KQL corroboration . . . 18
Gate 6 — Report is complete and reproducible . . . 18
Gate 7 — Whole-estate expand run . . . 18
6. Troubleshooting — Cloud Adoption Security Assessment 19
A pillar scores zero / discovery returns empty for one pillar . . . 19
`Connect-MgGraph` fails or `Authorization_RequestDenied` . . . 19
`Connect-AzAccount` succeeds but subscriptions are missing . . . 19
Secure Score in the script doesn't match the portal . . . 19
Conditional Access "gap" is actually covered . . . 19
KQL query errors on table or column names . . . 20
Report scores aren't reproducible . . . 20
Script "does nothing" / silent exit . . . 20
The assessment found a Defender product isn't turned on . . . 20
7. Best Practices — Cloud Adoption Security Assessment 20
Keep it read-only, keep it least-privilege . . . 20
Score against a named, current baseline — and record it . . . 21
Pilot before you present . . . 21
Rank by risk, sequence by effort . . . 21
Treat the report as sensitive . . . 21
Trend, don't snapshot-and-forget . . . 21
Leave the decisions with the owners . . . 21
Where to go next (adjacent catalog areas) . . . 22
8. Deliverables Summary — Cloud Adoption Security Assessment 22
Documentation . . . 22
Automation artifacts (all read-only) . . . 23
What the buyer receives . . . 24

Outcome 24
Appendix A — PowerShell Scripts 25

Executive Summary — Cloud Adoption Security Assessment

White-label · Assessments

Most organizations adopt or scale their Microsoft cloud faster than they secure it. Identity, endpoints, data, apps, and infrastructure each get stood up by a different team, on a different timeline, against no shared security baseline — and nobody can answer the one question a board or an auditor actually asks: *how secure is our cloud, and where is the risk highest?* This assessment answers it. It reviews your Microsoft 365 and Azure estate against the **Zero-Trust pillars** and the **Microsoft Cloud Adoption Framework (CAF)**, scores maturity pillar by pillar, and delivers a **risk-ranked findings report with a phased remediation roadmap** — the evidence to invest where it matters, not where it's loudest.

This is a complete, **run-it-yourself** package written for a competent administrator who has used the Microsoft admin portals but has never systematically scored a whole estate against Zero Trust, pulled Secure Score control profiles programmatically, or turned a pile of misconfigurations into a prioritized roadmap. The assessment is **strictly read-only**: every script observes and reports; **nothing in your tenant is changed**.

What you get

- A plain-language **Solution Overview** of the method — what Zero Trust and the Cloud Adoption Framework are, the six pillars this assessment scores (identity, endpoint, data, app, infrastructure, network), and how the read-only discovery, Secure Score, Conditional Access, and Defender posture reviews roll up into a maturity score.
- A **Requirements Guide** with verify / implement-if-missing for every solution-specific prerequisite (the category-wide ones live in the separate **Global Requirements — Assessments**).
- An **Implementation Guide** of precise, ordered steps — validate read-only access, discover the estate across all six pillars, pull Secure Score and Conditional Access coverage, score maturity against the reference baseline, then compile the risk-ranked findings and phased roadmap. Pilot on a scoped subset first, validate the findings, then expand to the whole estate.
- Five read-only **PowerShell** automation scripts (Microsoft Graph / Az / Defender) plus KQL guidance — discovery, access validation, Secure Score, Conditional Access coverage, and the prioritized findings report.
- **Testing** and **Troubleshooting** guides so you can trust the numbers before you present them.

What this delivers

A **scored, Zero-Trust-aligned picture** of your cloud security maturity: a per-pillar maturity rating (identity, endpoint, data, app, infrastructure, network) against a named reference baseline; your current **Microsoft Secure Score** with the highest-impact improvement actions surfaced; a **Conditional Access coverage** review (MFA for admins and users, legacy-auth block, device compliance, break-glass exclusions); a **Defender posture** summary across the products you own; and a single **risk-ranked findings report** that sequences the gaps into a phased roadmap (quick wins → foundational → strategic). A point-in-time snapshot you can re-run to trend the score as you remediate.

The standard deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — discover the estate, configure the scope and reference baseline, pilot the scoring on a representative subset, validate the findings against the live portals to weed out false positives, then expand to the full estate and produce the roadmap. The assessment supplies the technical evidence; **risk-acceptance, remediation priority, and any regulatory / records / legal determination remain the customer's decision** — made by your security, compliance, and leadership functions, not by this guide.

Outcome

A defensible, repeatable answer to "how secure is our cloud?" — a maturity score, a ranked list of the gaps that carry the most risk, and a phased roadmap to close them — produced by a single administrator, entirely read-only, and re-runnable to prove progress over time.

Scope boundary

This assessment **observes and scores the whole estate**; it does **not** remediate, and it does **not** replace the product-specific deep-dives. Onboarding and tuning each Defender product, building DLP, hunting threats, and running the SOC are covered by the dedicated catalog areas (Defender XDR unified onboarding, Defender CSPM, Defender for Office 365 hardening, Cloud App / DLP, SOC & XDR operations, and Threat Hunting). This gives you the **cross-cutting, whole-estate view and the roadmap**; those solutions do the fixing. Cross-referenced, not duplicated.

1. Solution Overview — Cloud Adoption Security Assessment

What this assessment is

This solution is a **cross-cutting, whole-estate security maturity assessment** of your Microsoft cloud — Microsoft 365 (Entra ID, Defender, Purview) and Azure — measured against two well-known reference frames: the **Zero-Trust** model and the **Microsoft Cloud Adoption Framework (CAF)**. It **discovers** what you have, **scores** how mature each security pillar is, and **prioritizes** the gaps into a phased roadmap. It is not a deployment and not a remediation: every script is **read-only** and changes nothing. The output is evidence — a maturity score and a ranked findings report — that tells leadership where the risk is highest and what to fix first.

Two reference frames sit behind the score, and it helps to separate them:

- **Zero Trust** is a security *model*: never trust, always verify; assume breach; enforce least privilege. Microsoft expresses it across six **pillars** — **identity, endpoints (devices), data, applications, infrastructure, and network** — plus the visibility/automation/governance that ties them together. This assessment scores each pillar.
- The **Cloud Adoption Framework (CAF)** is Microsoft's *lifecycle* guidance for adopting cloud well, with a **Secure** methodology and a **governance** discipline (management groups, policy, landing zones). This assessment uses CAF's Secure/Govern lens to judge whether your foundation (subscriptions, policy, guardrails) is set up to keep the estate secure as it grows. *Both frameworks and Microsoft's baselines evolve — verify against current Microsoft guidance when you run the assessment.*

The point of scoring against a named baseline, rather than eyeballing settings, is that **a number is comparable and defensible**. A pillar maturity score you can re-run tells you whether you are getting

better or worse; a ranked findings list tells a budget owner where a dollar buys the most risk reduction.

The six pillars this assessment scores

• **Identity.** Are admins and users protected by phishing-resistant MFA? Is legacy authentication blocked? Are privileged roles minimized and just-in-time (PIM)? Is Conditional Access actually covering the tenant, with sane break-glass exclusions? Identity is the new perimeter — it is scored first and weighted heavily.

• **Endpoints (devices).** Are devices enrolled and compliant (Intune)? Is Defender for Endpoint deployed and reporting? Is a compliance signal feeding Conditional Access so unhealthy devices are kept out?

• **Data.** Is sensitive data labeled and protected (sensitivity labels, DLP)? Are the highest-impact data-loss paths (email, endpoint, cloud apps) covered? *Data-classification decisions themselves are the customer's — the assessment scores whether controls exist, not what should be labeled.*

• **Applications.** Are OAuth app registrations and consent governed? Is shadow IT visible (Defender for Cloud Apps)? Are app secrets and expirations under control?

• **Infrastructure.** Is Defender for Cloud enabled with a healthy Secure Score? Are Azure resources covered by security policy and workload-protection plans? Are the CAF governance guardrails (management groups, Azure Policy) present?

• **Network.** Are public exposure and open management ports minimized? Are private endpoints used for PaaS? Is segmentation in place? (Assessed at the posture level; deep network penetration testing is out of scope.)

How the assessment works

• **Read-only discovery.** PowerShell using **Microsoft Graph** (including the **Security** endpoints), **Az** modules, and the **Defender** management APIs enumerates configuration across all six pillars. It authenticates as a **least-privilege read-only identity** (Security Reader / Global Reader / Azure Reader) and never holds write access — that is what proves it changes nothing.

• **Secure Score as an anchor.** Microsoft **Secure Score** is a first-class input: the assessment pulls your current score, the maximum, and the **control profiles** (identity, device, apps) so the highest-impact improvement actions surface automatically and feed the identity/endpoint/app pillar scores.

• **Conditional Access coverage.** A dedicated review enumerates every Conditional Access policy and tests for the coverage gaps that matter most — MFA for admins and all users, a legacy-auth block, device-compliance grants, and safe break-glass account exclusions — because a tenant can have many policies and still be exposed.

• **Defender posture.** Across the Defender products you own (Endpoint, Identity, Office 365, Cloud Apps, Cloud), the assessment records whether the plan is on, whether onboarding is healthy, and the headline posture — flagging *coverage gaps* (a product you own but haven't turned on) as findings.

• **KQL where it adds signal.** Where you have Microsoft Sentinel or Advanced Hunting, the guide supplies **read-only KQL** queries to corroborate posture (e.g. sign-ins still using legacy auth, devices not reporting) — evidence, never a change.

• **Scoring and ranking.** Findings roll up into a **per-pillar maturity score (0–100)** against the reference baseline, and each finding is tagged with a **risk rating** (impact × exposure) so the report can sequence a **phased roadmap**: quick wins, foundational, then strategic.

What you can control

• **Scope** — which subscriptions, which products, and which user/device population are in the assessment.

• **Reference baseline** — which benchmark you score against (Microsoft security baselines + Secure Score, with CIS / Zero Trust as applicable). *Verify the current baseline version.*

• **Weighting** — how heavily each pillar counts toward the overall score, if your organization deviates from the default.

• **Output handling** — where the (sensitive) findings report is stored and who may see it.

Scope — what's in

• A **read-only maturity assessment** across the six Zero-Trust pillars, using the CAF Secure/Govern lens for the foundation.

• **Secure Score** pull with control-profile detail and highest-impact actions.

• **Conditional Access** coverage/gap review.

• **Defender posture** summary across the products you own (coverage gaps flagged).

• A **risk-ranked findings report** and a **phased remediation roadmap**, plus an executive summary and technical findings.

Scope — what's out (be honest with buyers)

• **This does not remediate.** It observes and scores. Closing the gaps is done with the dedicated catalog solutions (see below) — pilot-first and change-controlled. This assessment is the map, not the roadworks.

• **Not a product deep-dive.** Onboarding/tuning each Defender product, building DLP policy, and standing up the SOC each have their own solution; this assessment references them rather than repeating them.

• **Not a penetration test.** Network and app posture are assessed at the configuration level; authorized offensive testing is a separate discipline.

• **No risk-acceptance or regulatory determination.** The assessment states the gap and its risk; **whether to accept a risk, how to prioritize against business need, and any regulatory / records / legal mapping are the customer's decisions**, made by security, compliance, and leadership.

Authentication and connections used

• **Microsoft Graph** (read scopes, including Security) signed in as **Security Reader / Global Reader** — for identity, Conditional Access, Secure Score, and Defender configuration (Global Requirements G2, G3).

• **Az PowerShell** signed in as **Reader** at the Azure scope — for Defender for Cloud, resource posture, and network exposure (G2, G3).

• **Microsoft Sentinel / Advanced Hunting** read access where present — for the corroborating KQL (optional).

• No write scopes are requested or used at any point — the read-only guarantee (G2).

The standard deployment model

> ***Assess the estate (discover configuration across all six pillars) → configure the scope, reference baseline, and pillar weighting → pilot the scoring on a representative subset (one business unit / subscription) → validate the findings against the live portals to remove false positives → expand to the full estate and produce the risk-ranked report and phased roadmap.***
> *The repeatable pattern: **Assess → Configure → Pilot → Validate → Expand** — entirely read-only, re-runnable to trend the score, with remediation handed to the dedicated solutions under change control.*

2. Requirements — Cloud Adoption Security Assessment

The category-wide prerequisites (the target tenant, read-only assessor access, Graph/Az API access, licensing, scope/baseline, output handling, remediation ownership) are published once in **Global Requirements — Assessments** — read that first. This page lists only the prerequisites **specific to this whole-estate assessment**. Each item: **Description / Why required / How to verify / How to implement if missing.**

> *Everything here is read-only. If any item can only be satisfied with write/admin access, that is a signal you have over-scoped the identity — an assessment needs to *read* configuration, nothing more.*

R1. Security Reader (or Global Reader) across Microsoft 365 / Entra

Description: A directory role that can read identity, Conditional Access, Secure Score, and Defender configuration tenant-wide — **Security Reader** is the least-privilege fit; **Global Reader** also works. **Why required:** The identity, endpoint, data, app, and Secure Score portions of the assessment read these blades via Graph; without the role the discovery scripts return empty or access-denied. **How to verify:** Entra admin center → **Roles and administrators** → confirm your account holds **Security Reader** or **Global Reader**. Then run `CLDSEC-Validate.ps1` — it confirms the effective read scopes. **How to implement if missing:** Have a Privileged Role Administrator assign **Security Reader**. Do **not** grant a write/admin role for the assessment — read-only is the point.

R2. Azure Reader at every in-scope subscription (and Security Reader on Defender for Cloud)

Description: The Azure RBAC **Reader** role at each subscription (or management group) in scope, plus **Security Reader** for Microsoft Defender for Cloud posture. **Why required:** The infrastructure and network pillars, and the Defender for Cloud Secure Score, are read through Azure Resource Manager; missing Reader means those pillars cannot be scored. **How to verify:** `portal.azure.com` → the subscription → **Access control (IAM)** → **View my access** → confirm **Reader**. `CLDSEC-Validate.ps1` also checks

`Connect-AzAccount` succeeds and lists in-scope subs. **How to implement if missing:** Have an Owner/User Access Administrator assign **Reader** at the subscription or management-group scope. Assign at the highest common scope so all in-scope subs are covered.

R3. Microsoft Graph read scopes consented

Description: Delegated read scopes for the Graph calls the scripts make — for example `SecurityEvents.Read.All`, `Policy.Read.All`, `Directory.Read.All`, `IdentityRiskEvent.Read.All`, `DeviceManagementConfiguration.Read.All`. *Verify the current scope names and least-privilege set for your tenant.* **Why required:** Graph enforces per-scope consent; without the read scopes, Secure Score, Conditional Access, and Defender configuration calls fail with `Authorization_RequestDenied`. **How to verify:** Run `Connect-MgGraph -Scopes <list>` and accept the consent prompt; `Get-MgContext` shows the granted scopes. `CLDSEC-Validate.ps1` reports which required scopes are present. **How to implement if missing:** Consent the read scopes at sign-in (delegated), or have an admin grant tenant-wide admin consent for the read-only scope set. Never request write scopes for this assessment.

R4. PowerShell 7+ with the Microsoft.Graph, Az, and (optional) Defender modules

Description: PowerShell 7 or later with **Microsoft.Graph**, **Az.Accounts / Az.Resources / Az.Security / Az.Network**, and — where you assess Defender for Endpoint directly — the relevant Defender API access. *Verify current module versions.* **Why required:** All five scripts are PowerShell and depend on these modules; version drift is the most common cause of a script that "does nothing". **How to verify:** `$PSVersionTable.PSVersion` ≥ 7; `Get-Module Microsoft.Graph,Az.Accounts -ListAvailable`. **How to implement if missing:** `Install-Module Microsoft.Graph -Scope CurrentUser` and `Install-Module Az -Scope CurrentUser`. Use a maintained PowerShell 7.x build.

R5. A defined, documented assessment scope

Description: A written scope — which subscriptions, which Defender/M365 products, which user and device population, and the pillar weighting if you deviate from the default — agreed before the run. **Why required:** Scope keeps the maturity score bounded and comparable run-to-run; an undocumented scope makes the score impossible to defend or trend. **How to verify:** The scope document exists and names the subscriptions/products; the assessment records the run date and scope in the report header. **How to implement if missing:** Agree the scope with the security owner before running. Start narrow (one business unit / one subscription) for the pilot, then expand.

R6. Microsoft Secure Score enabled and populated

Description: Microsoft Secure Score active in the Microsoft Defender portal with control profiles populated (it populates automatically once the relevant products are licensed and reporting). **Why required:** Secure Score is a core anchor for the identity/endpoint/app pillar scores and the highest-impact-actions list; an empty Secure Score removes that signal. **How to verify:** `security.microsoft.com` → **Secure Score** shows a current score and improvement actions. `CLDSEC-SecureScore.ps1` returns the score and control profiles. **How to implement if missing:** Ensure the products (Entra, Defender, Intune) are licensed

and reporting; Secure Score populates within a day or two. Note an absent Secure Score itself as a finding.

R7. (Optional) Sentinel / Advanced Hunting read access for corroborating KQL

Description: Reader access to a **Microsoft Sentinel** workspace or **Advanced Hunting** in the Defender portal, if you want to corroborate posture with the supplied read-only KQL (e.g. legacy-auth sign-ins). **Why required:** The KQL is optional corroboration; without it the assessment still scores from configuration, but you lose the live-signal cross-check. **How to verify:** You can open Advanced Hunting (`security.microsoft.com` → **Hunting**) or the Sentinel Logs blade and run a query. *Verify current portal location and licensing.* **How to implement if missing:** Grant **Microsoft Sentinel Reader** / Advanced Hunting read access, or skip the KQL corroboration — it is optional, not required, for the score.

R8. A secure destination for the findings report

Description: A restricted-access location to store the exported findings (CSV/JSON/report), which contains a detailed map of your weaknesses. **Why required:** The report is sensitive by nature; storing it loosely turns your assessment into an attacker's shopping list. **How to verify:** A restricted SharePoint/Teams site or secured file share exists and access is limited to the security owners. **How to implement if missing:** Provision a restricted destination before running; share findings on a need-to-know basis. *Risk-acceptance of any finding remains the customer's decision.*

Global Requirements — Assessments (category-level)

These requirements apply to every solution in the Assessments category (Security Optimization Assessments, remediation playbooks, and cross-cutting security assessments). Published once at the category level so listings stay small. Confirm these before running any assessment. Each entry: Description / Why / Verify / Implement-if-missing.

> *An assessment observes and scores; it does not change your tenant. Every assessment script here is **read-only** (the paired remediation work is separate and pilot-first). Scope, risk-acceptance, and remediation-priority decisions belong to the customer's security/compliance owners — the assessment supplies the evidence, not the authorization.*

G1. The workload/tenant being assessed

Description: An active Microsoft 365 / Entra tenant and/or Azure subscription(s) hosting the products in scope. Why: There is nothing to assess without the target environment. Verify: Sign in to the relevant portal(s) (`security.microsoft.com`, `portal.azure.com`) as an administrator. Implement: Ensure the target tenant/subscription exists and the products under assessment are deployed (even partially — assessing coverage gaps is the point).

G2. Read-only assessor access (least privilege)

Description: A read-only role sufficient to enumerate configuration — e.g. Security Reader, Global Reader, and/or Reader at the Azure scope. Why: An assessment must never require write access; read-only

proves it changes nothing. Verify: Entra -> `Roles and administrators`; confirm Security Reader / Global Reader (and Azure Reader where cloud resources are assessed). Implement: Assign the read-only roles; do not grant write/admin roles for the assessment itself.

G3. Microsoft Graph / Az / management API access

Description: Microsoft Graph (Security), Azure Resource Manager, and product-specific management APIs reachable with the assessor identity. Why: The assessment scripts collect configuration and posture via these APIs. Verify: `Connect-MgGraph` (read scopes) and `Connect-AzAccount` succeed; the assessment discovery script runs. *Verify current API/permission scopes.* Implement: Consent the read-only Graph scopes; ensure network access to the Microsoft endpoints.

G4. Licensing for the products in scope

Description: The licenses/plans for the products being assessed (e.g. Defender for Endpoint/Identity/Office 365/Cloud Apps plans, Defender for Cloud plans). Why: Some posture/configuration is only present (and only assessable) when the plan is enabled; the assessment flags plan gaps too. Verify: Confirm the relevant plans in the admin/billing portal. *Verify current plan/feature mapping.* Implement: Note unlicensed products as findings (a coverage gap) rather than skipping them silently.

G5. Scope definition and a point-in-time baseline

Description: A defined assessment scope (which products, subscriptions, and users) and the understanding that results are a point-in-time snapshot. Why: Scope keeps the assessment bounded and the score comparable; posture drifts, so results are dated. Verify: The scope is documented; the assessment records the run date. Implement: Agree the scope before running; re-run periodically to trend the score.

G6. Best-practice reference baseline

Description: The best-practice / benchmark the assessment scores against (Microsoft security baselines, Secure Score, CIS/Zero-Trust as applicable). Why: A score is only meaningful against a reference; the assessment states which baseline it uses. Verify: The reference baseline is named in the findings. *Baselines evolve — verify against current Microsoft guidance.* Implement: Use the documented baseline; note where organizational policy intentionally deviates.

G7. Output handling and confidentiality

Description: A place to store the findings report and an understanding that it may contain sensitive posture detail. Why: Assessment output is a roadmap of your weaknesses; it must be handled as sensitive. Verify: A secure destination for the report exists; access is restricted. Implement: Store findings securely; share on a need-to-know basis. *Risk-acceptance of any finding is the customer's decision.*

G8. Remediation ownership (for the paired remediation)

Description: Named owners for acting on findings (the remediation is separate, pilot-first work). Why: An assessment only creates value when someone owns closing the gaps. Verify: Remediation owners are identified; the Remediation Playbook solution is available for the fixes. Implement: Assign owners; use the

Remediation Playbook (pilot-first, -WhatIf-gated) to close findings and re-score.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation — Cloud Adoption Security Assessment

This is the exact, ordered procedure. It is **read-only** end to end — you enumerate and score, you never change the tenant. Follow the standard model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**. Run the **pilot** on one representative scope first, confirm the findings are real, then expand to the whole estate.

Naming convention. Every artifact you create uses `<Purpose> – <Scope> – <Stage>`. Reuse the exact names in later steps, testing, and the report:

- Scope document: `CloudSecAssessment – Estate – Scope`
- Output folder: `CloudSecAssessment – Estate – Findings`
- Pilot run label: `CloudSecAssessment – FinancePilot – Pilot`
- Full run label: `CloudSecAssessment – Estate – Full`
- Roadmap deliverable: `CloudSecAssessment – Estate – Roadmap`
- Saved KQL query: `CloudSecAssessment – LegacyAuth – Signal`

Stage 0 — Assess: prepare and validate access (read-only)

Step 0.1 — Write the scope document

1. Create `CloudSecAssessment – Estate – Scope` (a short doc). Record: the subscriptions in scope, the

M365/Defender products in scope, the user/device population, the **reference baseline** you will score against (Microsoft security baselines + Secure Score; add CIS / Zero Trust if your org uses them — *verify the current baseline version*), and any non-default **pillar weighting**.

1. Note the **run date** — the score is a point-in-time snapshot (Global Requirements G5).

Step 0.2 — Create the output folder

1. Create a restricted folder named `CloudSecAssessment – Estate – Findings` in your secure destination

(R8). All exports land here.

Step 0.3 — Install modules and validate read-only access

1. In **PowerShell 7+**: `Install-Module Microsoft.Graph -Scope CurrentUser` and

`Install-Module Az -Scope CurrentUser` if not present (R4).

1. Connect read-only:

- `Connect-MgGraph -Scopes "SecurityEvents.Read.All","Policy.Read.All","Directory.Read.All","DeviceManagementConfiguration.Read.All"` *(verify the current

least-privilege scope set for your tenant)*.

• `Connect-AzAccount` and, if needed, `Set-AzContext -SubscriptionId <sub>`.

1. Run `CLDSEC-Validate.ps1`. It confirms: PowerShell version, required modules present, the Graph

scopes granted, that your identity is **read-only** (Security/Global Reader, Azure Reader), and lists the in-scope subscriptions. **Do not proceed until Validate passes** — a missing scope means a pillar will silently score zero.

Stage 1 — Configure: choose the baseline and pilot scope

1. In `CloudSecAssessment – Estate – Scope`, confirm the **reference baseline** and record it — the

report must name what it scored against (G6).

1. Pick a **representative pilot scope** — one business unit or one subscription — and label it

`CloudSecAssessment – FinancePilot – Pilot` (rename to your BU). The pilot proves the method and surfaces false positives before you run the whole estate.

1. Confirm the **pillar weighting** (default: identity and endpoints weighted highest). Record any deviation.

Stage 2 — Pilot: discover and score the pilot scope (read-only)

Step 2.1 — Estate discovery across the six pillars

1. Run `CLDSEC-Discovery.ps1 -Scope "CloudSecAssessment – FinancePilot – Pilot" -OutputFolder "<...>\CloudSecAssessment – Estate – Findings"`.

For the pilot, point it at the pilot subscription/BU. It enumerates, read-only:

• **Identity** — MFA registration coverage, legacy-auth exposure, privileged role counts and PIM usage, risky-user/sign-in signals.

• **Endpoints** — device enrollment and compliance counts (Intune), Defender for Endpoint onboarding state.

• **Data** — sensitivity-label and DLP policy presence and scope.

• **Applications** — OAuth app registrations, risky/consented permissions, secret/expiry status; Cloud Apps (shadow IT) visibility state.

• **Infrastructure** — Defender for Cloud plan state and Secure Score, Azure Policy assignments, CAF governance guardrails (management groups) presence.

• **Network** — public IP / open management-port exposure, private-endpoint usage on PaaS.

1. It writes a per-pillar posture CSV/JSON into the output folder.

Step 2.2 — Pull Secure Score and control profiles

1. Run `CLDSEC-SecureScore.ps1 -OutputFolder "<...>\CloudSecAssessment – Estate – Findings"`. It returns

your current Secure Score, the maximum, the per-category control profiles (identity/device/apps), and the **highest-impact improvement actions** — which feed the pillar scores and the roadmap.

Step 2.3 — Review Conditional Access coverage

1. Run `CLDSEC-ConditionalAccess.ps1 -OutputFolder "<...>\CloudSecAssessment – Estate – Findings"`. It

enumerates every CA policy (enabled + report-only) and flags the coverage gaps that matter most:

- No **phishing-resistant MFA** for admins / all users.
- **Legacy authentication** not blocked.
- No **device-compliance** grant.
- **Break-glass** account exclusions missing or mis-scoped (an emergency-access account must be excluded).

1. *Note: the assessment reports gaps; it does not create or change any CA policy. Building/enforcing CA

policy is a separate, pilot-first remediation — see Best Practices for the pointer.*

Step 2.4 — (Optional) corroborate with KQL

1. If you have Advanced Hunting / Sentinel (R7), run the read-only query saved as

`CloudSecAssessment – LegacyAuth – Signal` (supplied in Testing) to confirm whether legacy-auth sign-ins are still happening in the pilot scope — live evidence behind the config finding.

Step 2.5 — Score and rank the pilot

1. Run `CLDSEC-Report.ps1 -InputFolder "<...>\CloudSecAssessment – Estate – Findings" -Label "CloudSecAssessment – FinancePilot – Pilot"`.

It rolls the discovery + Secure Score + CA outputs into a **per-pillar maturity score (0–100)** against the recorded baseline, tags each finding with a **risk rating** (impact × exposure), and emits a draft risk-ranked findings report.

Stage 3 — Validate: confirm the pilot findings are real

1. Open the draft report. For each **High/Critical** finding, open the corresponding live portal blade and

confirm it is genuine — this removes false positives before anyone sees the numbers:

- Identity/CA → Entra admin center → **Conditional Access** and **Users** → **Authentication methods**.
- Endpoints → `intune.microsoft.com` → **Devices** compliance; `security.microsoft.com` → device inventory.
- Data → Microsoft Purview → **Information Protection** / **DLP**.
- Infra → `portal.azure.com` → **Microsoft Defender for Cloud** → Secure Score / Recommendations.

1. Mark any confirmed false positive in the report and note why (e.g. a compensating control the script can't see). **Do not silently delete findings** — record the reasoning.

1. Sanity-check the pilot pillar scores against your own expectation. If a pillar scored zero, re-check that the matching Graph scope / Azure Reader role was present (a common cause — see Troubleshooting).

Stage 4 — Expand: run the whole estate and produce the roadmap

1. Re-run **Steps 2.1–2.5** with the full scope, labelled `CloudSecAssessment – Estate – Full` — point `CLDSEC-Discovery.ps1` at all in-scope subscriptions and the full user/device population.

1. Run `CLDSEC-Report.ps1 ... -Label "CloudSecAssessment – Estate – Full"` to produce the final **risk-ranked findings report** with per-pillar maturity scores and an **overall maturity rating**.

1. Build the phased roadmap `CloudSecAssessment – Estate – Roadmap` from the ranked findings, in three phases:

• **Phase 1 — Quick wins:** high-impact, low-effort (e.g. block legacy auth, exclude break-glass from enforcement gaps, turn on a Defender plan you already own).

• **Phase 2 — Foundational:** MFA/CA coverage, device compliance gates, DLP baseline, Defender for Cloud plan enablement.

• **Phase 3 — Strategic:** PIM/least-privilege program, data-classification program, network segmentation, landing-zone governance.

1. Map each roadmap item to the **dedicated catalog solution** that remediates it (Defender XDR onboarding, Defender CSPM, Cloud App / DLP, SOC & XDR, Threat Hunting) — the assessment hands the fix off; it does not perform it.

1. Store the report and roadmap in `CloudSecAssessment – Estate – Findings` (restricted). Present the executive summary (overall score + top risks) to leadership and the technical findings to the owners.

> ***Determinations that are NOT yours to make in this guide:*** *whether to *accept* any given risk, how to prioritize against business need and budget, and any* ***regulatory / records / legal*** *mapping of a finding belong to your security, compliance, and leadership functions. The assessment supplies the evidence and a recommended sequence; the decisions are the customer's.*

Re-run to trend

The whole assessment is re-runnable. Re-run quarterly (or after a remediation wave) with the same scope and baseline to **trend the maturity score** and prove risk reduction over time.

5. Testing — Cloud Adoption Security Assessment

Testing an assessment means proving the **evidence is trustworthy** before anyone acts on it: the access is truly read-only, the discovery is complete (no pillar silently empty), the scores reconcile with the live portals, and the report is reproducible. Work the gates in order; each has an explicit **pass/fail**. All tests are read-only.

Scripts referenced (all read-only): `CLDSEC-Validate.ps1`, `CLDSEC-Discovery.ps1`, `CLDSEC-SecureScore.ps1`, `CLDSEC-ConditionalAccess.ps1`, `CLDSEC-Report.ps1`.

Gate 1 — Access is valid and read-only

Run `CLDSEC-Validate.ps1`.

- **Pass:** PowerShell ≥ 7; required modules present; Graph read scopes granted; identity resolves to **Security/Global Reader** and **Azure Reader**; in-scope subscriptions listed; **no write scope present**.
- **Fail:** Any missing module/scope, or a write/admin role detected. Fix per Requirements R1–R4 before continuing — a missing scope makes a pillar score falsely zero; a write role breaks the read-only guarantee.

Gate 2 — Discovery is complete (no empty pillars)

Run `CLDSEC-Discovery.ps1` on the pilot scope.

- **Pass:** All six pillars (identity, endpoint, data, app, infra, network) return non-empty posture rows, and the output CSV/JSON lands in `CloudSecAssessment – Estate – Findings`.
- **Fail:** A pillar returns empty. Check the matching prerequisite — e.g. an empty Infrastructure pillar usually means Azure **Reader** (R2) is missing; an empty Data pillar means the Purview/Graph scope (R3) is missing. Re-run after fixing.

Gate 3 — Secure Score reconciles with the portal

Run `CLDSEC-SecureScore.ps1`, then open `security.microsoft.com` → **Secure Score**.

- **Pass:** The score, maximum, and top improvement actions returned by the script **match** the portal (allowing for the portal's own refresh lag).
- **Fail:** Numbers diverge materially. Confirm Secure Score is populated (R6) and that you are reading the same tenant; re-run.

Gate 4 — Conditional Access gaps are real

Run `CLDSEC-ConditionalAccess.ps1`, then open Entra admin center → **Conditional Access**.

- **Pass:** Every gap the script flags (no admin MFA, legacy auth not blocked, no device-compliance grant,

break-glass exclusion missing) is confirmed by inspecting the live policies; the policy count matches.

- **Fail:** A flagged gap is actually covered by a policy the script misread (e.g. a report-only policy about

to be enabled). Record it as a validated false positive in the report with the reason — do not delete it silently.

Gate 5 — (Optional) KQL corroboration

If you have Advanced Hunting / Sentinel (R7), run the saved query `CloudSecAssessment – LegacyAuth – Signal`:

```
// Read-only. Legacy-authentication sign-ins in the assessment window — corroborates the CA "legacy auth
// not blocked" finding with live evidence. *Verify table/column names for your workspace.*
SigninLogs
| where TimeGenerated > ago(7d)
| where ClientAppUsed in ("Other clients","IMAP4","POP3","SMTP","Exchange ActiveSync","Authenticated SMTP"
| summarize Attempts = count(), Users = dcount(UserPrincipalName) by ClientAppUsed
| order by Attempts desc
```

- **Pass:** The query runs read-only and either confirms legacy-auth is still occurring (supports the finding)

or returns zero (note as a compensating signal).

- **Fail:** Query errors on table/column names — adjust to your workspace schema (*verify current schema*) or

skip; KQL corroboration is optional and does not gate the score.

Gate 6 — Report is complete and reproducible

Run `CLDSEC-Report.ps1` for the labelled run.

- **Pass:** The report contains a per-pillar maturity score (0–100), an overall rating, every finding tagged

with a risk rating, and the **named reference baseline and run date** in the header; re-running on the same inputs produces the same scores.

- **Fail:** Missing scores, no baseline named, or non-reproducible numbers. Confirm all Stage-2 outputs are

present in the input folder and re-run.

Gate 7 — Whole-estate expand run

Repeat Gates 2–6 with the full scope labelled `CloudSecAssessment – Estate – Full`.

- **Pass:** All gates pass at full scope; the roadmap `CloudSecAssessment – Estate – Roadmap` sequences

the findings into Phase 1/2/3 and each item maps to a remediation solution.

- **Fail:** A pillar that passed at pilot scope now fails at full scope — usually a subscription where Reader

wasn't assigned. Fix the scope coverage (R2, R5) and re-run.

> *Passing all gates means the evidence is defensible. It does **not** authorize any change — remediation is separate, pilot-first, and change-controlled, and risk-acceptance is the customer's decision.*

6. Troubleshooting — Cloud Adoption Security Assessment

Common failures when running the assessment, as **symptom** → **cause** → **fix**. Everything here stays read-only — no fix below changes tenant configuration.

A pillar scores zero / discovery returns empty for one pillar

Symptom: `CLDSEC-Discovery.ps1` returns rows for some pillars but the Infrastructure (or Data, or App) pillar is empty, and that pillar scores zero. **Cause:** The read role or Graph scope for that pillar is missing — Infrastructure needs Azure **Reader** (R2); Data/App need the Purview/directory Graph scopes (R3). A missing scope reads as "nothing there," which the score can't distinguish from "nothing configured." **Fix:** Run `CLDSEC-Validate.ps1` and compare the granted scopes/roles against R1–R3. Assign the missing **Reader** role or consent the missing read scope, then re-run discovery for that pillar. Never assume an empty pillar means it's insecure *or* secure until access is confirmed.

`Connect-MgGraph` fails or `Authorization_RequestDenied`

Symptom: Sign-in fails, or Secure Score / Conditional Access calls return `Authorization_RequestDenied`. **Cause:** The required delegated read scopes weren't consented, or admin consent is required in your tenant. **Fix:** Re-run `Connect-MgGraph -Scopes <list>` and accept consent; if the tenant blocks user consent, have an admin grant admin consent for the **read-only** scope set (R3). `Get-MgContext` should then list the scopes. Never substitute a write scope to "make it work."

`Connect-AzAccount` succeeds but subscriptions are missing

Symptom: Azure connects, but in-scope subscriptions don't appear and the Infrastructure/Network pillars under-report. **Cause: Reader** isn't assigned at those subscriptions, or your context is set to a different tenant/sub. **Fix:** `Get-AzSubscription` to list what you can see; assign **Reader** at the missing subscription or management group (R2), then `Set-AzContext` and re-run. Confirm the tenant matches the M365 tenant.

Secure Score in the script doesn't match the portal

Symptom: `CLDSEC-SecureScore.ps1` returns a different score than `security.microsoft.com`. **Cause:** Portal refresh lag (Secure Score recalculates on its own cadence), or you're reading a different tenant, or Secure Score isn't fully populated (R6). **Fix:** Allow for the portal's refresh window; confirm the tenant; confirm Secure Score is populated. Small differences are normal timing; large differences mean a tenant/scope mismatch — recheck and re-run.

Conditional Access "gap" is actually covered

Symptom: `CLDSEC-ConditionalAccess.ps1` flags "no admin MFA" but you believe a policy covers it. **Cause:** The control lives in a **report-only** policy (not yet enforced), a policy scoped by group the script

didn't expand, or a Security Defaults configuration. **Fix:** Open the live CA policies and confirm the effective state. If it's genuinely covered, mark it a **validated false positive** in the report with the reason (Testing Gate 4) — don't delete it silently. If it's report-only, it is *not* yet enforced, so the finding stands until it's turned on (a separate, pilot-first remediation).

KQL query errors on table or column names

Symptom: The `CloudSecAssessment – LegacyAuth – Signal` query fails with an unknown table/column. **Cause:** Schema differs between Sentinel workspaces and Advanced Hunting, and schemas evolve. **Fix:** Adjust the table/column names to your workspace (*verify current schema*), or skip it — the KQL is **optional** corroboration and does not gate the maturity score.

Report scores aren't reproducible

Symptom: Re-running `CLDSEC-Report.ps1` on the "same" data yields different scores. **Cause:** The input folder changed between runs (a discovery output was overwritten or partially written), or two runs used different scope labels. **Fix:** Ensure all Stage-2 outputs for the run label are present and complete in the input folder before running the report; keep pilot and full-estate outputs in clearly labelled subfolders (`... – Pilot` vs `... – Full`). Re-run.

Script "does nothing" / silent exit

Symptom: A script runs and returns almost immediately with no output. **Cause:** Module version drift (R4) or no matching resources in the current context. **Fix:** Confirm PowerShell ≥ 7 and current **Microsoft.Graph** / **Az** modules; confirm you're connected and in the right context. Run `CLDSEC-Validate.ps1` first — it catches the common environment problems before the substantive scripts run.

The assessment found a Defender product isn't turned on

Symptom: A product you're licensed for shows as not onboarded / plan off. **Cause:** This is a **finding, not an error** — a coverage gap is exactly what the assessment exists to surface. **Fix:** Record it as a finding and map it to the remediation solution (Defender XDR onboarding / Defender CSPM). Turning it on is separate, change-controlled work — not part of this read-only assessment.

7. Best Practices — Cloud Adoption Security Assessment

Field-proven guidance for running a whole-estate security assessment that people trust and act on — plus where to go next to close the gaps.

Keep it read-only, keep it least-privilege

- **Never** run the assessment with a write or admin role "to be safe." An assessment that could change the

tenant is no longer an assessment. Use **Security/Global Reader** + **Azure Reader** and let `CLDSEC-Validate.ps1` prove it.

• Consent only the **read** Graph scopes. If a script ever needs a write scope, treat it as a bug, not a requirement.

Score against a named, current baseline — and record it

• Always name the **reference baseline** in the report (Microsoft security baselines + Secure Score; CIS / Zero Trust if your org uses them). *Baselines evolve — verify against current Microsoft guidance each run.*

• Record the **scope and run date** in the report header so the score is comparable and defensible. A score with no baseline and no date is an opinion, not evidence.

Pilot before you present

• Run the **pilot scope** first and **validate High/Critical findings against the live portal** before the full run. False positives destroy credibility faster than missing findings.

• When you confirm a false positive, **record why** (a compensating control the script can't see) — don't quietly delete it.

Rank by risk, sequence by effort

• Present findings **risk-ranked** (impact × exposure), then sequence the roadmap by effort: **quick wins → foundational → strategic**. A budget owner funds the roadmap that shows the cheapest risk reduction first.

• Weight **identity and endpoints** highest by default — they are the most common breach entry points — but record any deviation your organization intentionally makes.

Treat the report as sensitive

• The findings report is a **map of your weaknesses**. Store it in the restricted `CloudSecAssessment – Estate – Findings` location and share on a need-to-know basis. Never email it broadly or drop it in an open channel.

Trend, don't snapshot-and-forget

• The value compounds when you **re-run** with the same scope and baseline after each remediation wave, and chart the maturity score over time. A rising score is the single best evidence that security spend is working.

Leave the decisions with the owners

• The assessment states each gap and its risk and recommends a sequence. **Whether to accept a risk, how to

prioritize against business need, and any regulatory / records / legal mapping are the customer's decisions** — made by security, compliance, and leadership, not by this guide or its scripts.

Where to go next (adjacent catalog areas)

This assessment is the **map**; these solutions do the **roadworks** (each pilot-first and change-controlled):

• **Identity & Conditional Access hardening / Zero-Trust identity** — to build the MFA, legacy-auth-block,

device-compliance, and PIM controls the identity pillar flagged.

• **Defender XDR unified onboarding** — to turn on and connect the Defender products where the assessment

found coverage gaps.

• **Defender for Cloud (CSPM) posture management** — to raise the infrastructure Secure Score and close the

Azure resource findings.

• **Defender for Office 365 hardening** and **Cloud App / DLP** — for the email, app-consent, shadow-IT, and

data-loss findings.

• **SOC & XDR operations** and **Threat Hunting** — to operationalize detection and hunt against the residual

risk once the roadmap is under way.

• **AI Workload Security Assessment** (sibling assessment) — if your estate now includes Azure AI workloads,

assess that new attack surface with the paired AI-specific assessment.

Close the top-ranked findings, then **re-run this assessment** to prove the score moved.

8. Deliverables Summary — Cloud Adoption Security Assessment

Documentation

Document	Purpose
Executive Summary	The business case and what's in the box — a scored, Zero-Trust-aligned view of cloud security maturity and a phased roadmap

Document	Purpose
1. Solution Overview	What the assessment is — Zero Trust + CAF, the six pillars scored, how read-only discovery, Secure Score, Conditional Access, and Defender posture roll up into a maturity score; scope and the boundary vs. the remediation solutions
2. Requirements	Solution-specific prerequisites with Verify / Implement-if-missing
Global Requirements (Assessments)	Category-wide prerequisites, published once
3. Implementation	Exact, ordered, read-only steps — validate access, discover across six pillars, pull Secure Score and CA coverage, score maturity, pilot → validate → expand, then produce the risk-ranked report and phased roadmap
5. Testing	Validation gates — read-only proof, complete discovery, portal reconciliation, reproducible report
6. Troubleshooting	Field issues → cause → fix
7. Best Practices	Field-proven guidance and where to go next to close the gaps

Automation artifacts (all read-only)

File	What it does
`CLDSEC-Discovery.ps1`	**PowerShell, read-only.** Whole-estate discovery across the six Zero-Trust pillars (identity, endpoint, data, app, infrastructure, network) via Microsoft Graph + Az — MFA/legacy-auth/PIM, device compliance + Defender for Endpoint state, label/DLP presence, app-consent/secrets + shadow-IT visibility, Defender for Cloud + policy guardrails, and public-exposure/private-endpoint posture. Writes per-pillar posture to the findings folder.
`CLDSEC-Validate.ps1`	**PowerShell, read-only.** Pre-flight — confirms PowerShell/module versions, the granted Graph read scopes, that the identity is Security/Global Reader + Azure Reader (no write), and lists the in-scope subscriptions. The gate that proves the run is read-only and complete before you score.

File	What it does
`CLDSEC-SecureScore.ps1`	**PowerShell, read-only.** Pulls Microsoft Secure Score, the maximum, and the per-category control profiles (identity/device/apps) with the highest-impact improvement actions — the anchor for the identity/endpoint/app pillar scores and the roadmap.
`CLDSEC-ConditionalAccess.ps1`	**PowerShell, read-only.** Enumerates every Conditional Access policy (enabled + report-only) and flags the coverage gaps that matter most — no admin/user MFA, legacy auth not blocked, no device-compliance grant, break-glass exclusion missing/mis-scoped. Reports gaps; changes nothing.
`CLDSEC-Report.ps1`	**PowerShell, read-only.** Rolls the discovery + Secure Score + CA outputs into a per-pillar maturity score (0–100) against the named baseline, tags each finding with a risk rating (impact × exposure), and emits the risk-ranked findings report with the reference baseline and run date in the header.

Plus **read-only KQL** (saved as `CloudSecAssessment – LegacyAuth – Signal`) in the Testing guide to corroborate the legacy-auth finding with live sign-in evidence where Sentinel / Advanced Hunting is available.

What the buyer receives

- This assessment guide as a **Word** document and **PDF**.
- All five read-only **PowerShell** scripts plus the KQL, in a single ZIP.
- A repeatable process following the model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — entirely

read-only, re-runnable to trend the maturity score, with remediation handed to the dedicated catalog solutions under change control.

Delivered as a Complete Solution Package (PDF + Word + scripts).

Outcome

A defensible answer to "how secure is our cloud?" — a per-pillar maturity score, a risk-ranked list of the gaps that carry the most risk, and a phased roadmap to close them — produced by a single administrator, entirely read-only, and re-runnable to prove progress. Risk-acceptance and remediation-priority decisions remain the customer's.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CLDSEC-ConditionalAccess.ps1

Purpose: Enumerates every Conditional Access policy (enabled and report-only) and tests for the coverage gaps that most often leave a tenant exposed even when many policies exist: no phishing-resistant MFA for admins or all users, legacy authentication not blocked, no device-compliance grant, and break-glass / emergency-access accounts not excluded from enforcement. It REPORTS gaps only — it never creates, edits, enables, or disables a policy. Building/enforcing CA policy is a separate, pilot-first remediation. HOW TO RUN Connect-MgGraph -Scopes "Policy.Read.All" pwsh -File .\CLDSEC-ConditionalAccess.ps1 -OutputFolder "<secure path>" Optionally: -BreakGlassUpns "bg-admin1@contoso.com","bg-admin2@contoso.com" EXPECTED RESULTS A policy inventory and a gap checklist (PASS/GAP) with the policy names involved. CSV written to the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. contoso.com is a placeholder. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OutputFolder, [string[]]$BreakGlassUpns)

How to run: Connect-MgGraph -Scopes "Policy.Read.All" pwsh -File .\CLDSEC-ConditionalAccess.ps1 -OutputFolder "<secure path>" Optionally: -BreakGlassUpns "bg-admin1@contoso.com","bg-admin2@contoso.com" EXPECTED RESULTS A policy inventory and a gap checklist (PASS/GAP) with the policy names involved. CSV written to the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. contoso.com is a placeholder. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OutputFolder, [string[]]$BreakGlassUpns)

CLDSEC-Discovery.ps1

Purpose: Builds the point-in-time posture baseline for the maturity score. Enumerates configuration across Identity, Endpoints, Data, Applications, Infrastructure, and Network using Microsoft Graph and Az, and writes a per-pillar posture set (CSV/JSON) into the findings folder. Every call is read-only; nothing in the tenant is changed. Coverage gaps (a product owned but not enabled) are captured as posture rows so the report can flag them as findings. HOW TO RUN Connect-MgGraph -Scopes "SecurityEvents.Read.All","Policy.Read.All","Directory.Read.All","DeviceManagementConfiguration.Read.All" Connect-AzAccount pwsh -File .\CLDSEC-Discovery.ps1 -Label "CloudSecAssessment - Estate - Full" -OutputFolder "<secure path>" Run CLDSEC-Validate.ps1 first. *Verify current Graph/Az cmdlet and property names for your tenant.* EXPECTED RESULTS A per-pillar posture table on screen and per-pillar CSV/JSON files in the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. Best-effort across API surfaces — verify property names. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$Label, [Parameter(Mandatory=$true)][string]$OutputFolder, [string[]]$SubscriptionIds)

How to run: Connect-MgGraph -Scopes "SecurityEvents.Read.All","Policy.Read.All","Directory.Read.All", "DeviceManagementConfiguration.Read.All" Connect-AzAccount pwsh -File .\CLDSEC-Discovery.ps1 -Label "CloudSecAssessment - Estate - Full" -OutputFolder "<secure path>" Run CLDSEC-Validate.ps1 first. *Verify current Graph/Az cmdlet and property names for your tenant.* EXPECTED RESULTS A per-pillar posture table on screen and per-pillar CSV/JSON files in the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. Best-effort across API surfaces — verify property names. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$Label, [Parameter(Mandatory=$true)][string]$OutputFolder, [string[]]$SubscriptionIds)

CLDSEC-Report.ps1

Purpose: Consumes the CSV/JSON produced by CLDSEC-Discovery.ps1, CLDSEC-SecureScore.ps1, and CLDSEC-ConditionalAccess.ps1 from the input folder and produces: a per-pillar maturity score (0-100) against the recorded reference baseline, an overall maturity rating, and a risk-ranked findings list where each item is tagged Critical/High/Medium/Low (impact x exposure) and mapped to a suggested remediation area. It reads files only — it makes no tenant calls and changes nothing. HOW TO RUN pwsh -File .\CLDSEC-Report.ps1 -InputFolder "<findings folder>" -Label "CloudSecAssessment - Estate - Full" -Baseline "Microsoft security baselines + Secure Score (verify version)" EXPECTED RESULTS A Markdown findings report and a CSV of ranked findings written to the input folder, plus an on-screen summary (per-pillar scores + top risks). Read-only. .NOTES White-label. Read-only. Reads the discovery outputs only; makes no tenant changes. Scoring is a transparent heuristic — adjust weights to your organization's agreed model. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$InputFolder, [Parameter(Mandatory=$true)][string]$Label, [string]$Baseline = 'Microsoft security baselines + Secure Score (verify current version)')

How to run: pwsh -File .\CLDSEC-Report.ps1 -InputFolder "<findings folder>" -Label "CloudSecAssessment - Estate - Full" -Baseline "Microsoft security baselines + Secure Score (verify version)" EXPECTED RESULTS A Markdown findings report and a CSV of ranked findings written to the input folder, plus an on-screen summary (per-pillar scores + top risks). Read-only. .NOTES White-label. Read-only. Reads the discovery outputs only; makes no tenant changes. Scoring is a transparent heuristic — adjust weights to your organization's agreed model. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$InputFolder, [Parameter(Mandatory=$true)][string]$Label, [string]$Baseline = 'Microsoft security baselines + Secure Score (verify current version)')

CLDSEC-SecureScore.ps1

Purpose: Retrieves the current Microsoft Secure Score, the maximum attainable, the per-category control profiles (identity / device / apps / data), and the highest-impact improvement actions still open. These anchor the identity/endpoint/app pillar scores and populate the "quick wins" in the roadmap. Read-only; nothing is changed. HOW TO RUN Connect-MgGraph -Scopes "SecurityEvents.Read.All" pwsh -File .\CLDSEC-SecureScore.ps1 -OutputFolder "<secure path>" Verify the current Graph Security Secure Score endpoints/permissions for your tenant.* EXPECTED RESULTS The current score vs max, per-category breakdown, and the top open improvement actions by points. A CSV of the control profiles is written to the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OutputFolder, [int]$TopActions = 15)

How to run: Connect-MgGraph -Scopes "SecurityEvents.Read.All" pwsh -File .\CLDSEC-SecureScore.ps1 -OutputFolder "<secure path>" Verify the current Graph Security Secure Score endpoints/permissions for your tenant.* EXPECTED RESULTS The current score vs max, per-category breakdown, and the top open improvement actions by points. A CSV of the control profiles is written to the output folder. Read-only. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$OutputFolder, [int]$TopActions = 15)

CLDSEC-Validate.ps1

Purpose: The gate you run before any substantive discovery. Confirms PowerShell and module versions, that Microsoft Graph and Azure are connected, which Graph read scopes are granted, that the signed-in identity is read-only (Security/Global Reader + Azure Reader, with NO write/admin role detected), and lists the in-scope Azure subscriptions. If this does not pass, a pillar can silently score zero or the read-only

guarantee is broken — so fix findings here first. HOW TO RUN Connect-MgGraph -Scopes "SecurityEvent s.Read.All","Policy.Read.All","Directory.Read.All","DeviceManagementConfiguration.Read.All" Connect-AzAccount pwsh -File .\CLDSEC-Validate.ps1 Requires PowerShell 7+ and the Microsoft.Graph and Az modules. *Verify current scope names/modules.* EXPECTED RESULTS A PASS/WARN/FAIL checklist. All PASS = ready to run CLDSEC-Discovery.ps1. Nothing is changed. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([string[]]$RequiredScopes = @('SecurityEvent s.Read.All','Policy.Read.All','Directory.Read.All','DeviceManagementConfiguration.Read.All'))

How to run: Connect-MgGraph -Scopes "SecurityEvents.Read.All","Policy.Read.All","Directory.Read.All", "DeviceManagementConfiguration.Read.All" Connect-AzAccount pwsh -File .\CLDSEC-Validate.ps1 Requires PowerShell 7+ and the Microsoft.Graph and Az modules. *Verify current scope names/modules.* EXPECTED RESULTS A PASS/WARN/FAIL checklist. All PASS = ready to run CLDSEC-Discovery.ps1. Nothing is changed. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([string[]]$RequiredScopes = @('SecurityEvents.Read.All','Policy.Read.All','Directory.Read.All','DeviceMan agementConfiguration.Read.All'))